Chapter 2
Secure architecture and Principles of secure designing

Abhijeet Pasi

Department of Computer Engineering

K J Somaiya School of Engineering

Outline

- What Is Security Architecture?
- Types of Security Architecture
- Elements of Security Architecture
- Security Architecture Frameworks
- Why Do We Need Security Architecture?
- Benefits of Security Architecture
- Summary

What Is Security Architecture?

- Security architecture is a **strategic blueprint** that defines how an organization designs and implements security controls to protect systems, data, and networks from threats.
- It includes policies, risk management processes, controls, and technologies to ensure data confidentiality, integrity, and availability.

Types of Security Architecture

- **Network Security Architecture:** Protects organizational networks with tools like firewalls and intrusion detection.
- **Application Security Architecture:** Embeds secure coding, encryption, and authentication within software.
- **Cloud Security Architecture:** Secures cloud platforms using identity/access controls, encryption, and audits.
- **Enterprise Information Security Architecture (EISA):** A wide-scope architecture that aligns people, processes, and technology with business goals.
- **Wireless Security Architecture:** Focuses on securing wireless networks using encryption (e.g., WPA3), access control, etc.
- **Endpoint Security Architecture:** Protects devices like laptops and phones using antivirus, EDR tools, and device management.

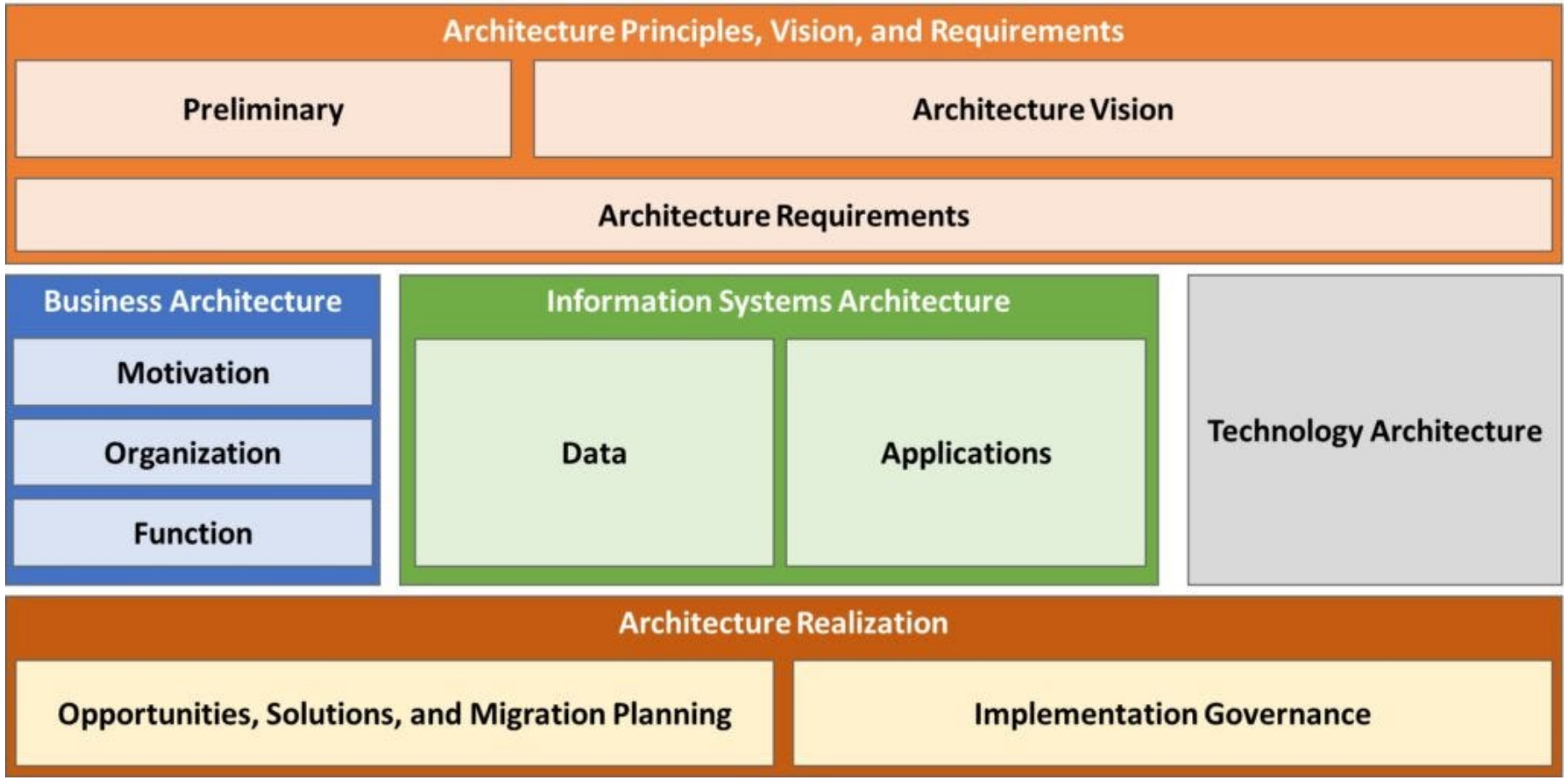
Elements of Security Architecture

- Key components that make up effective security architecture include:
  - **Security Framework** – Standards and policies guiding security design and implementation.
  - **Security Management** – Activities to detect, prevent, and respond to threats.
  - **Risk Management** – Identifying, evaluating, and controlling risks to assets.
  - **Identity and Access Management (IAM)** – Controls who can access what.
  - **Encryption** – Protects data from unauthorized access.
  - **Issue Response** – Steps to manage incidents and reduce impact.
  - **Security Training** – Educating personnel about security risks and best practices.

Security Architecture Frameworks

- These are structured approaches or standards that help implement security architecture:
  - TOGAF (The Open Group Architecture Framework) – Strategic IT framework including security design.
  - SABSA (Sherwood Applied Business Security Architecture) – Risk-based security model aligning with business needs.
  - Zachman Framework – Organizes architectural perspectives, including security concerns.
  - NIST Cybersecurity Framework – Best practices and guidelines for risk management.
  - ISO/IEC 27001 – Standards for information security management systems (ISMS).
  - MITRE ATT&CK – Threat matrix used to plan defenses and assess security posture.

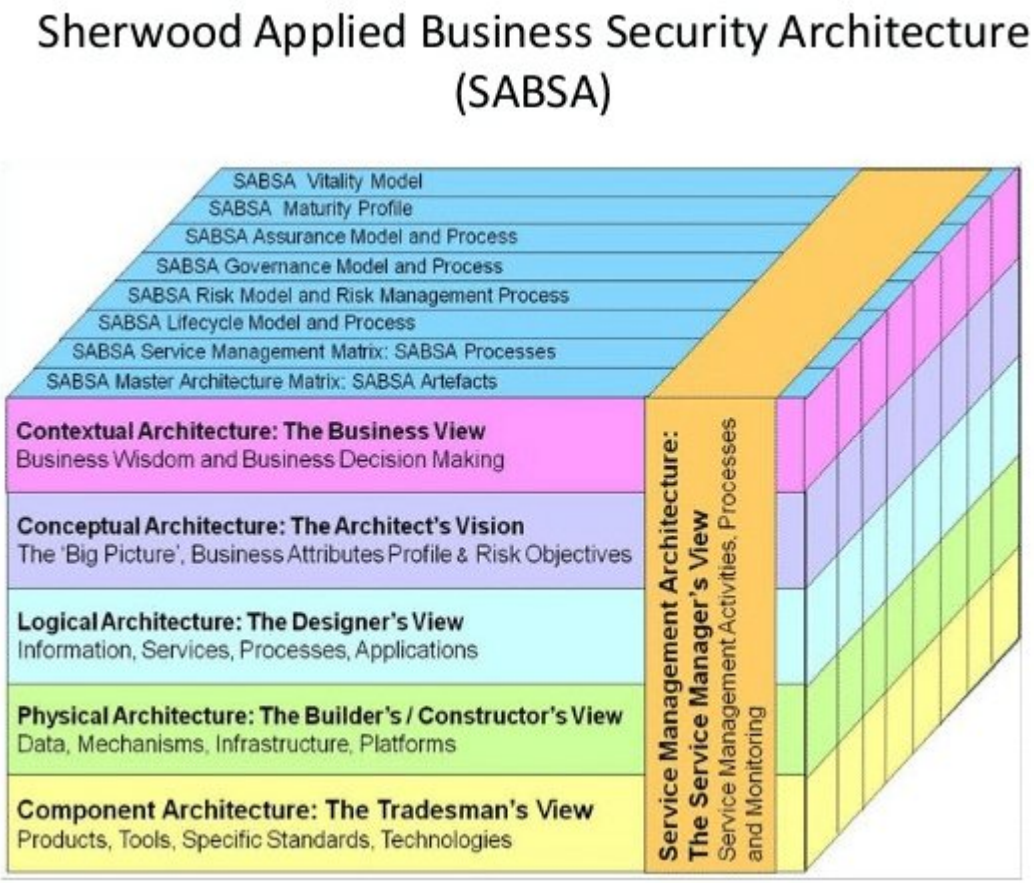
TOGAF (The Open Group Architecture Framework)



TOGAF (The Open Group Architecture Framework)

- Enterprise framework for designing and managing IT architecture.
- Uses the Architecture Development Method (ADM) for structured architecture development.
- ADM is Step-by-step process for developing and managing enterprise architecture
- Aligns business strategy with IT systems
- Open, vendor-neutral, and industry-accepted standard
- Supports governance, risk management, and security integration

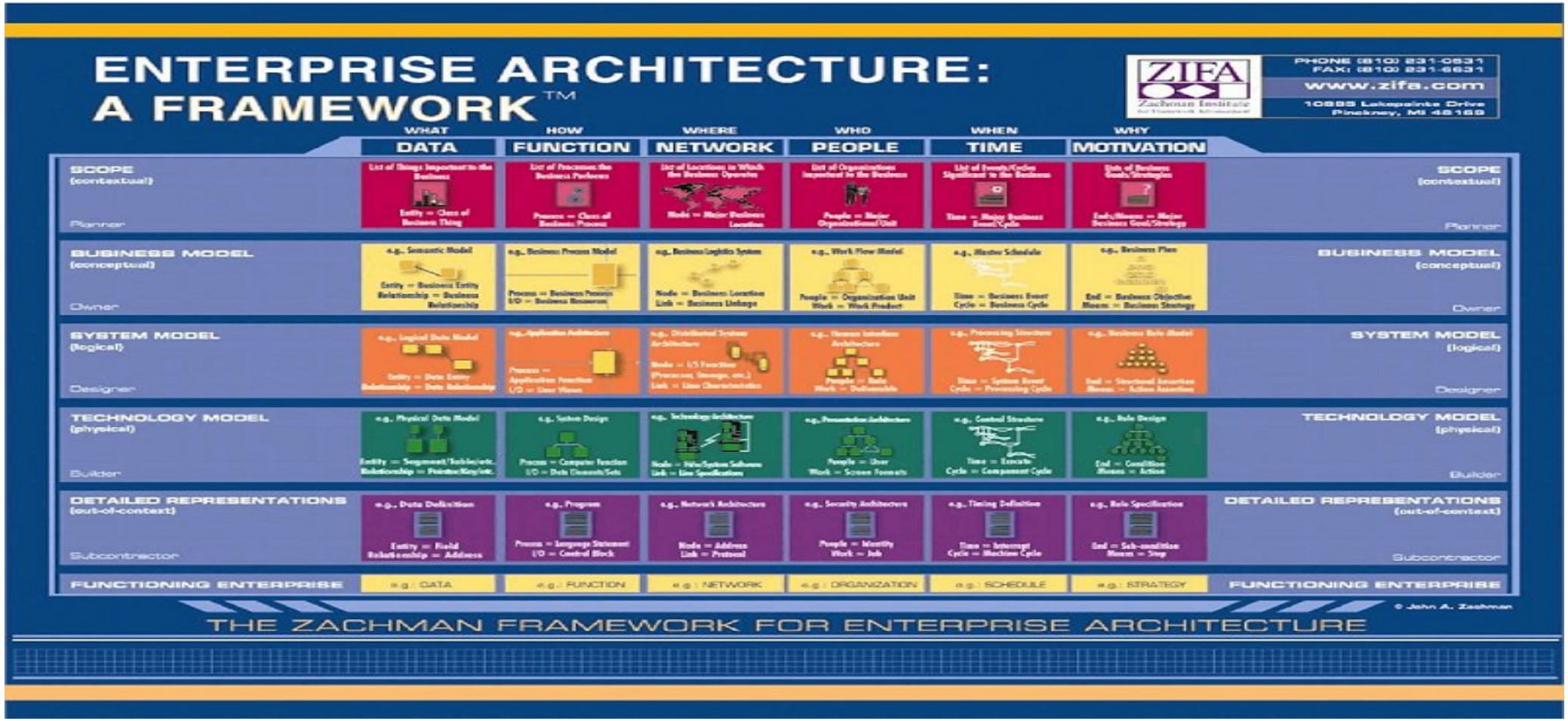
SABSA (Sherwood Applied Business Security Architecture)



SABSA (Sherwood Applied Business Security Architecture)

- Risk-driven security architecture framework
- Aligns security with business objectives.
- Uses a layered and traceable architecture model.
- Focuses on governance, risk, and compliance.
- Supports enterprise-wide security design

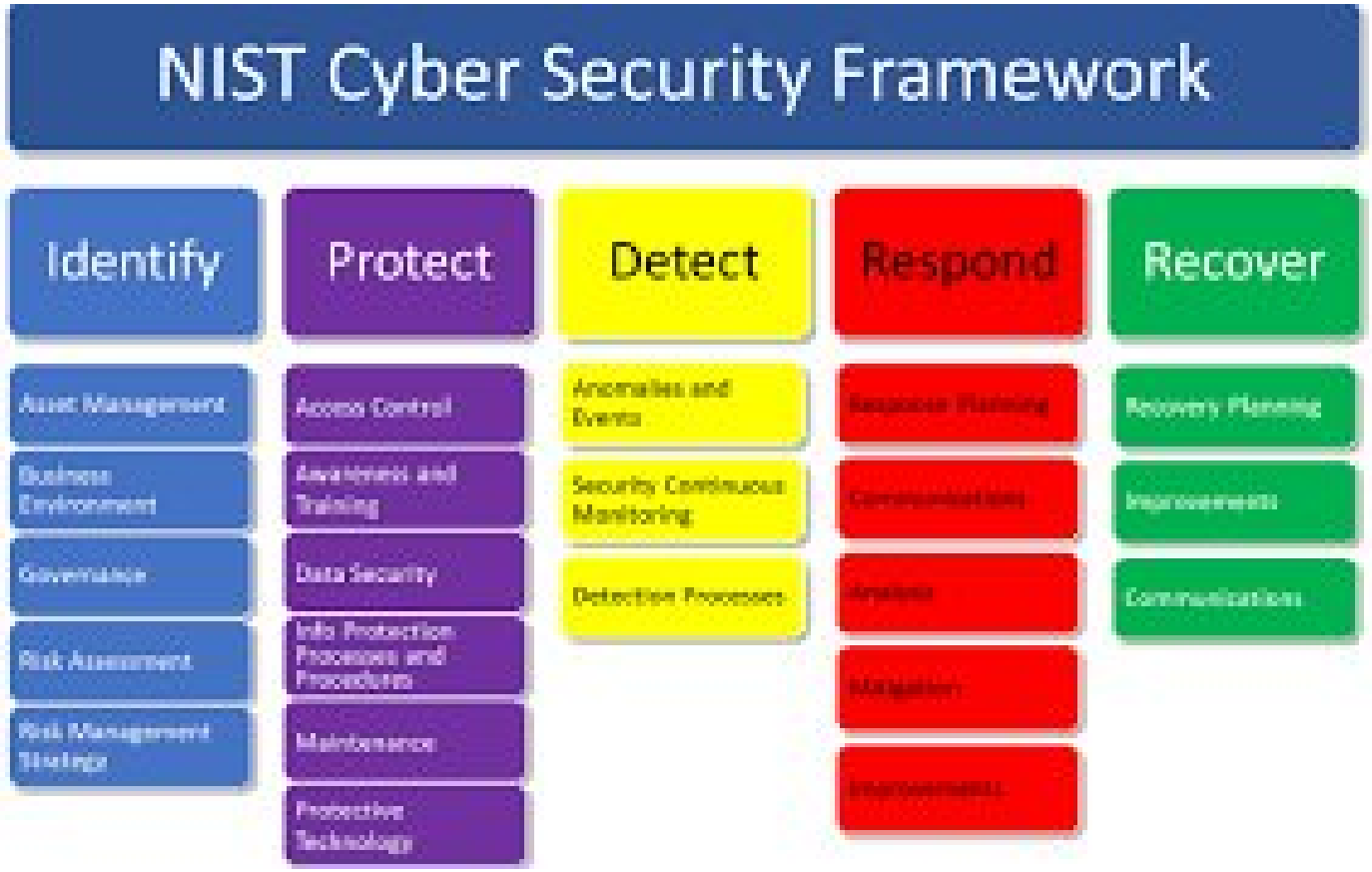
Zachman Framework



Zachman Framework

- Enterprise architecture classification and taxonomy framework.
- Organizes architecture using rows and columns.
- Addresses what, how, where, who, when, why.
- Provides multiple stakeholder perspectives.
- Supports structured and holistic system design

NIST Cybersecurity Framework



NIST Cybersecurity Framework

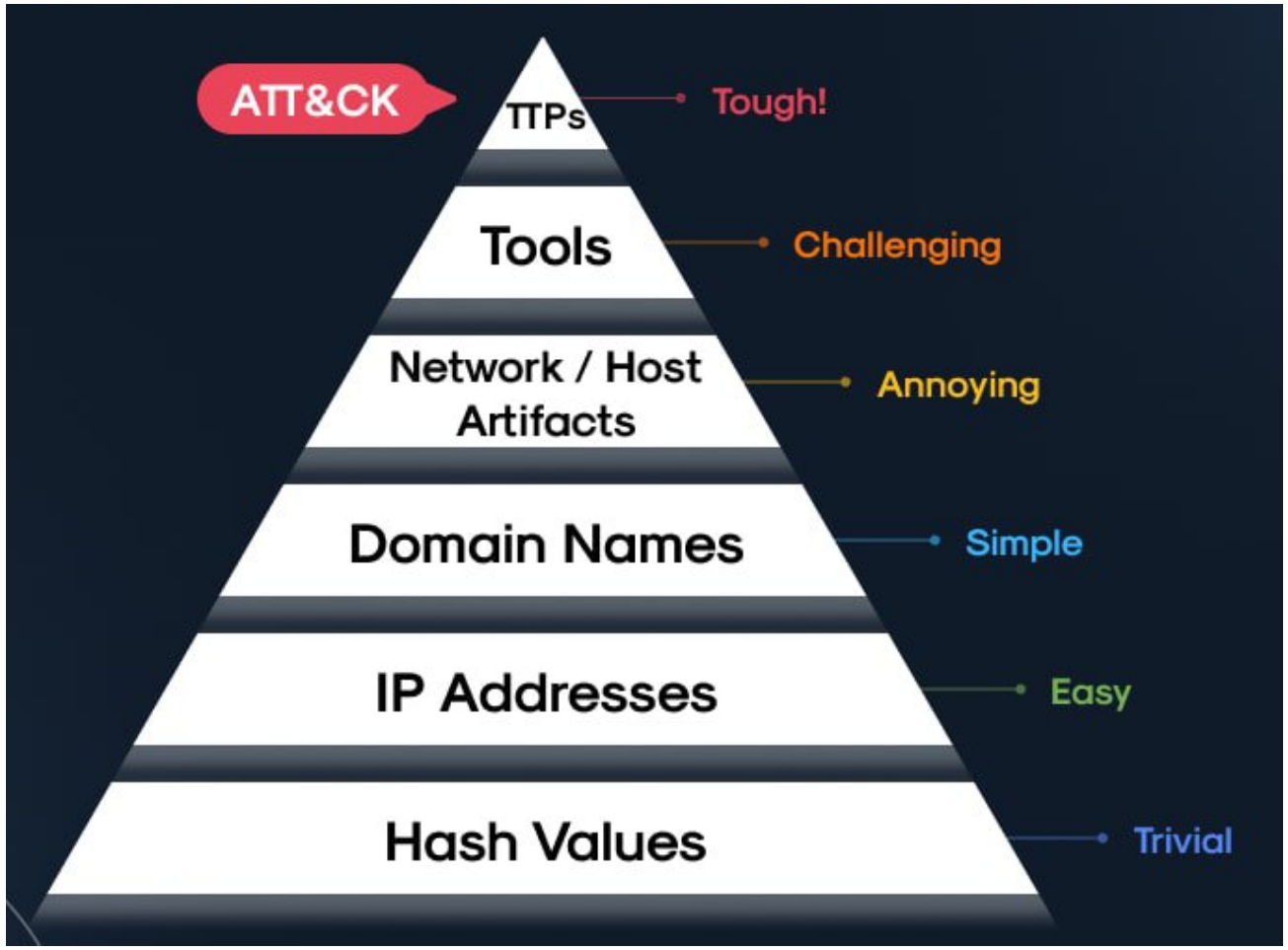
- Risk-based framework for managing cybersecurity.
- Organized into Identify, Protect, Detect, Respond, Recover
- Improves security posture through best practices
- Supports compliance and risk management
- Applicable across industries and organizations

ISO/IEC 27001

ISO/IEC 27001

- International standard for information security management systems.
- Focuses on confidentiality, integrity, and availability.
- Uses a risk-based security controls approach.
- Supports certification and regulatory compliance.
- Ensures continuous improvement of information security

MITRE ATT&CK


ATT&CK
TTPs
Tough!
Tools
Challenging
Network / Host Artifacts
Annoying
Domain Names
Simple
IP Addresses
Easy
Hash Values
Trivial

MITRE ATT&CK

- Knowledge base of adversary tactics and techniques.
- Based on real-world cyberattack behaviors.
- Improves threat detection and defense planning.
- Maps attacks across enterprise environments.
- Supports security assessment and threat modeling

Why Do We Need Security Architecture?

- Security architecture is essential because it:
  - Helps mitigate risks before they become breaches.
  - Aligns security with business goals so the organization stays protected while operating efficiently.
  - Improves resource prioritization based on actual risks.
  - Strengthens incident response and recovery.
  - Supports regulatory compliance and audits.

Benefits of Security Architecture

- Organizations gain many advantages, such as:
  - Better security management and risk control.
  - Efficient use of resources for security.
  - Enhanced incident handling and business continuity.
  - Improved privacy and data protection.
  - Increased trust from customers and stakeholders.

Summary

- Security architecture is a blueprint for protecting systems, networks, and data.
- Covers multiple areas: network, application, cloud, endpoint security.
- Core goals: confidentiality, integrity, and availability (CIA triad)
- Uses frameworks like TOGAF, SABSA, NIST, ISO 27001, MITRE ATT&CK
- Benefits: risk reduction, compliance, better incident response, business alignment